CRISC Domain D - 100 More Impossible Hard Questions

Information Technology and Security - Expert Level Part 3

CRISC Mastery Series

October 21, 2026

Warning

Extreme Difficulty

Domain D is technical but the exam tests judgment, not trivia.
Every option will look plausible.
Think like a risk practitioner advising on technology, not a technician.

Outline

1. 1. Enterprise Architecture
2. 2. IT Operations and Change Management
3. 3. Enterprise Resiliency
4. 4. Data Lifecycle Management
5. 5. SDLC and Emerging Technologies
6. 6. Information Security Principles

Q201: Architecture Decision Records

Question

Why are Architecture Decision Records (ADRs) valuable for governance?

A. They document every meeting minute

B. They capture context, rationale, and consequences of key architecture decisions

C. They replace architecture reviews

D. They eliminate risk

Q201: Explanation

Correct Answer: B

ADRs preserve rationale:

- Capture context and options considered
- Explain why a decision was made
- Support audit and future teams

Critical Trap

ADRs record decisions and reasoning, not meetings.

Q202: Capability-Based Planning

Question

What does capability-based planning in EA emphasize?

A. Vendor preferences
B. Delivering business capabilities that enable strategy
C. Buying the newest tools
D. Cutting costs only

Q202: Explanation

Correct Answer: B

Capabilities enable strategy:

- Focus on business capabilities
- Technology supports capabilities
- Reduces technology-driven decisions

Critical Trap

Capability-based planning starts from business capabilities.

Q203: Architecture Debt Trade-Off

Question

When might it be ACCEPTABLE to take on architecture debt?

A. Always, to save time
B. When the debt is time-bound and has a documented repayment plan
C. Never
D. When vendors ask

Q203: Explanation

Correct Answer: B

Managed debt is acceptable:

- Short-term business need
- Documented and tracked
- Repayment plan agreed

Critical Trap

Architecture debt is acceptable only if managed and repaid.

Q204: TOGAF Architecture Governance

Question

What does TOGAF architecture governance typically include?

A. Only documentation

B. Architecture board, compliance reviews, and dispensations

C. Only marketing

D. Only legal

Q204: Explanation

Correct Answer: B

Governance includes board and dispensations:

- Architecture board
- Compliance reviews
- Dispensations for exceptions

Critical Trap

Governance includes exception mechanisms, not just rules.

Q205: Business Architecture Artifacts

Question

Which is a typical business architecture artifact?

A. Firewall rules
B. Business process model and capability map
C. Server configuration
D. Network diagrams

Q205: Explanation

Correct Answer: B

Business architecture uses process and capability models:

- Business processes
- Capability maps
- Organizational models

Critical Trap

Business architecture = processes and capabilities.

Q206: Application Portfolio Management

Question

What does application portfolio management aim to do?

A. Buy more apps

B. Rationalize apps to remove redundancy and optimize value

C. Ignore business needs

D. Eliminate IT

Q206: Explanation

Correct Answer: B

Rationalize and optimize:

- Identify redundant apps
- Retire low-value apps
- Align portfolio to business

Critical Trap

APM reduces duplication and improves value.

Q207: Reference Model Use

Question

What is a risk of relying on reference models without adaptation?

- A Guaranteed success
- B Mismatch with actual business context and priorities
- C Reduced cost
- D Perfect fit

Q207: Explanation

Correct Answer: B

Reference models need tailoring:

- Context differs
- Priorities differ
- Adaptation is required

Critical Trap

Reference models are starting points, not mandates.

Q208: Architecture Requirements

Question

What should architecture requirements be derived from?

A. Vendor marketing

B. Business requirements and strategy

C. Personal preferences

D. Social media

Q208: Explanation

Correct Answer: B

Architecture serves business:

- Business requirements
- Strategy alignment
- Stakeholder needs

Critical Trap

Architecture requirements follow business, not vendors.

Q209: Architecture Review Value

Question

What is the primary value of an architecture review?

A. Slowing down projects

B. Detecting misalignment and risk before investment

C. Increasing costs

D. Avoiding governance

Q209: Explanation

Correct Answer: B

Review catches issues early:

- Detects misalignment
- Reduces rework
- Saves cost

Critical Trap

Architecture reviews reduce risk, not add bureaucracy.

Q210: EA Roadmap

Question

What does an EA roadmap provide?

- A Vendor list
- B Sequenced transition plan from current to target state
- C Only budgets
- D Only diagrams

Q210: Explanation

Correct Answer: B

Roadmap sequences the transition:

- Current to target state
- Prioritized projects
- Dependencies and milestones

Critical Trap

Roadmaps sequence change, not just document it.

Q211: Change Backout Plan

Question

What should a backout plan include?

- A Only approval signatures
- B Steps, verification, and communication to revert the change safely
- C Only costs
- D Only vendor names

Q211: Explanation

Correct Answer: B

Backout plan must be executable:

- Clear steps
- Verification methods
- Communication plan

Critical Trap

Backout plan must be testable and clear.

Q212: Problem Management Value

Question

Why is problem management valuable for risk reduction?

A. Faster tickets

B. It removes recurring incidents by addressing root causes

C. It increases workload

D. It avoids audits

Q212: Explanation

Correct Answer: B

Problem management eliminates root causes:

- Reduces recurring incidents
- Frees resources
- Improves stability

Critical Trap

Problem management reduces risk by eliminating causes.

Q213: Release Calendar

Question

Why is a release calendar valuable?

A. Marketing

B. Coordinates releases to avoid conflicts and business disruption

C. Hides changes from business

D. Ignores testing

Q213: Explanation

Correct Answer: B

Calendar coordinates deployment:

- Avoids release collisions
- Aligns with business periods
- Reduces risk

Critical Trap

Release calendar prevents chaos, not just schedules.

Q214: Test Environment Parity

Question

Why should test environments mirror production closely?

A. Cheaper

B. To catch issues that would occur in production before release

C. Faster

D. Smaller

Q214: Explanation

Correct Answer: B

Parity catches real issues:

- Configuration and dependency differences cause failures
- Production parity reduces surprises
- Testing quality improves

Critical Trap

Unrealistic test environments miss real issues.

Q215: Change Emergency Retrospective

Question

What should happen after an emergency change?

A. Nothing
B. Retrospective review and document to verify controls and learn
C. Cancel it
D. Ignore it

Q215: Explanation

Correct Answer: B

Emergency changes require retrospective:

- Verify it was justified
- Confirm testing occurred
- Capture lessons

Critical Trap

Emergency without retrospective is unmanaged.

Q216: Runbook Value

Question

What is the value of an operations runbook?

A. Marketing

B. Consistent execution of operational tasks and recovery procedures

C. Higher cost

D. Larger teams

Q216: Explanation

Correct Answer: B

Runbooks standardize execution:

- Reduce errors
- Consistent response
- Faster onboarding

Critical Trap

Runbooks reduce reliance on memory.

Q217: Operations KPI Choice

Question

Which KPI is most useful for operations leadership?

- A Number of tickets opened
- B Availability and mean time to resolve critical incidents
- C Number of meetings
- D Number of employees

Q217: Explanation

Correct Answer: B

Availability and MTTR show stability:

- Availability impacts business
- MTTR shows response capability
- Ticket volume is workload, not outcome

Critical Trap

Leadership cares about stability, not workload.

Q218: Monitoring Coverage

Question

Why is monitoring coverage important?

A. Cheaper
B. Detects issues proactively before users report them
C. Faster tickets
D. Less training

Q218: Explanation

Correct Answer: B

Coverage prevents surprises:

- Proactive detection
- Reduced downtime
- Better user experience

Critical Trap

Unmonitored systems fail silently.

Q219: Alerting Tuning

Question

What is the main benefit of tuning alerts?

A. Fewer alerts always means safer

B. Reduces noise so critical alerts stand out and response improves

C. Cheaper

D. Slower response

Q219: Explanation

Correct Answer: B

Tuning improves signal:

- Noise hides critical alerts
- Tuning improves response
- Alert fatigue is a risk

Critical Trap

Too many alerts means too few responses.

Q220: Post-Incident Actions

Question

Which is the MOST important output of an incident review?

- A Blame
- B Action items with owners and timelines to reduce recurrence
- C Ticket closure
- D Budget increase

Q220: Explanation

Correct Answer: B

Actions drive improvement:

- Actions drive improvement
- Owners ensure follow-through
- Timelines create accountability

Critical Trap

Incident reviews without actions are theater.

Q221: Recovery Site Selection

Question

Which factor MOST influences recovery site selection?

A. Cost only
B. Business RTO, RPO, and cost trade-offs
C. Vendor preference
D. Marketing

Q221: Explanation

Correct Answer: B

Balance recovery with cost:

- RTO and RPO define requirements
- Cost constrains choices
- Site fits business needs

Critical Trap

Site selection balances recovery objectives with cost.

Q222: Cloud DR Benefits

Question

What is the MAIN benefit of cloud-based DR?

A. Free

B. Scalable recovery without owning a second data center

C. No testing needed

D. No security controls

Q222: Explanation

Correct Answer: B

Scale without owning a second site:

- Rapid scaling
- Reduced cost of standby
- Still requires testing and security

Critical Trap

Cloud DR still requires testing and security.

Q223: Failover Automation Risk

Question

What risk is introduced by fully automated failover?

A. Slower recovery

B. Automated failover can be triggered by false positives and cause outage

C. Higher cost

D. Fewer tests

Q223: Explanation

Correct Answer: B

False positives cause outages:

- False triggers cause disruption
- Requires careful tuning
- Manual override should exist

Critical Trap

Automation reduces time but can misfire.

Q224: Backup Encryption

Question

Why should backups be encrypted?

A. Slower restore

B. Protect sensitive data if backups are lost or stolen

C. Cheaper

D. Less space

Q224: Explanation

Correct Answer: B

Protect sensitive backup data:

- Backups contain sensitive data
- Encryption protects if media lost
- Keys must be protected separately

Critical Trap

Unencrypted backups are a data exposure risk.

Q225: Backup Isolation

Question

What is the purpose of isolating backups from production networks?

A. Speed

B. Prevent attackers from reaching and encrypting backups

C. Cheaper

D. Easier restore

Q225: Explanation

Correct Answer: B

Isolation protects backups:

- Ransomware spreads
- Isolation protects backups
- Offline or air gap best

Critical Trap

Connected backups are vulnerable to ransomware.

Q226: BCP Coverage

Question

What should a BCP cover beyond IT recovery?

A. Only servers
B. People, facilities, suppliers, communications, and processes
C. Only backups
D. Only firewalls

Q226: Explanation

Correct Answer: B

Continuity is business-wide:

- Business continuity is broad
- People and facilities matter
- Suppliers matter
- Communications matter

Critical Trap

BCP covers more than IT; it covers the business.

Q227: Crisis Leadership

Question

What is MOST important in crisis leadership?

A. Hiding the problem

B. Clear decisions, communication, and direction with delegated authority

C. Slower meetings

D. More approvals

Q227: Explanation

Correct Answer: B

Clear decisions and communication:

- Crises require speed
- Clear authority
- Consistent communication

Critical Trap

Ambiguous leadership lengthens crises.

Q228: Vendor Dependency in DR

Question

What risk exists if a DR provider is also a single point of failure?

A. No risk
B. Concentration risk if the provider fails during the same event
C. Cheaper recovery
D. Faster recovery

Q228: Explanation

Correct Answer: B

Concentrated DR is risky:

- Shared geography or vendor
- Concentrated risk
- Use diverse providers

Critical Trap

DR providers can be part of a concentration risk.

Q229: Recovery Metrics

Question

Which metric measures data loss tolerance?

A. RTO
B. RPO
C. MTD
D. MTTR

Q229: Explanation

Correct Answer: B

RPO measures data loss:

- RPO is acceptable data loss
- RTO is recovery time target
- MTD is max tolerable outage

Critical Trap

RPO is about data loss; RTO is about time.

Q230: Third-Party Recovery Testing

Question

Why is testing recovery for third-party dependencies important?

A. Trust contracts

B. Verify recovery actually works with external providers, not just assumptions

C. Cheaper

D. Faster

Q230: Explanation

Correct Answer: B

Tests verify promises:

- Contracts promise
- Tests verify
- Real world differs

Critical Trap

Contracts do not replace recovery testing.

Q231: Data Lineage

Question

What is the purpose of data lineage in data management?

- A Marketing
- B Trace where data came from, how it moved, and where it is used
- C Cheaper
- D Backups

Q231: Explanation

Correct Answer: B

Lineage provides traceability:

- Traceability
- Supports governance
- Enables impact analysis

Critical Trap

Lineage provides data traceability, not just storage.

Q232: Data Masking

Question

When should data masking be used?

A. Never
B. When using production-like data in non-production environments
C. Only in production
D. Only for archives

Q232: Explanation

Correct Answer: B

Masking for non-production:

- Protects sensitive fields
- Enables realistic testing
- Avoids exposure

Critical Trap

Masking is required when production-like data is used in testing.

Q233: Pseudonymization vs Anonymization

Question

What is the key difference?

A. They are the same

B. Pseudonymization is reversible with a key; anonymization is not reversible

C. Anonymization is reversible

D. Pseudonymization is not reversible

Q233: Explanation

Correct Answer: B

Reversibility differs:

- Pseudonymization is reversible with key
- Anonymization is permanent
- GDPR treats them differently

Critical Trap

Pseudonymized data is still personal data.

Q234: Data Retention Audit

Question

Why should retention schedules be audited?

A. To show effort

B. To verify data is not retained beyond legal limits

C. To reduce storage only

D. To avoid training

Q234: Explanation

Correct Answer: B

Audit ensures compliance:

- Over-retention risk
- Legal exposure
- Compliance requires proof

Critical Trap

Retention schedules must be enforced and audited.

Q235: Data Steward Role

Question

What does a data steward typically do?

A. Runs the helpdesk

B. Maintains quality, classification, and metadata for data under their care

C. Owns the firewall

D. Manages HR

Q235: Explanation

Correct Answer: B

Stewards manage quality and metadata:

- Quality assurance
- Metadata
- Compliance with data policy

Critical Trap

Stewards manage data quality and metadata, not systems.

Q236: Data Classification Oversharing

Question

What is the risk of over-classifying data as highly confidential?

A. Improved productivity

B. Excessive controls slow work, cost more, and reduce trust in classification

C. Higher productivity

D. Lower cost

Q236: Explanation

Correct Answer: B

Over-classification is costly:

- Controls proportionate
- Over-classification erodes compliance
- Classification must be accurate

Critical Trap

Over-classification is as damaging as under-classification.

Q237: Cross-Border Retention

Question

Why do data retention rules differ across jurisdictions?

A. No reason
B. Different laws, cultures, and regulatory priorities
C. Random
D. Marketing

Q237: Explanation

Correct Answer: B

Legal variation:

- Legal variation
- Sector-specific rules
- Multi-jurisdiction complexity

Critical Trap

Multi-jurisdiction retention requires legal mapping.

Q238: Data Destruction Verification

Question

How should an organization verify destruction on sanitized media?

A. Trust the vendor

B. Certificates, third-party verification, or sampling

C. Assume

D. Ignore

Q238: Explanation

Correct Answer: B

Verify destruction:

- Certificates
- Sampling
- Audit trails

Critical Trap

Destruction without verification is not defensible.

Q239: DLP Coverage Limits

Question

What is a limitation of DLP tools?

A. Perfect detection

B. Cannot catch all sensitive data, especially unstructured content or encrypted channels

C. Cheaper than alternatives

D. Replaces training

Q239: Explanation

Correct Answer: B

DLP has limits:

- Content inspection limits
- Encrypted traffic bypasses
- Complement with other controls

Critical Trap

DLP is not a silver bullet; combine controls.

Q240: Data Privacy by Default

Question

What does privacy by default require in data lifecycle?

A. Collect all data
B. Default settings minimize data collection and sharing
C. Force users to opt out
D. Ignore regulations

Q240: Explanation

Correct Answer: B

Minimize by default:

- Strictest settings default
- Users opt in to sharing
- GDPR principle

Critical Trap

Privacy by default = minimized data sharing by default.

Q241: DevSecOps Principle

Question

What is the core principle of DevSecOps?

- A Security after deployment
- B Security integrated throughout development and operations
- C Security only in audit
- D No security

Q241: Explanation

Correct Answer: B

Security in every phase:

- Security in every phase
- Automation of checks
- Shared responsibility

Critical Trap

DevSecOps integrates security, it does not add it late.

Q242: CI/CD Security Gates

Question

What role do security gates play in CI/CD?

- A Slow down deployments only
- B Prevent vulnerable or non-compliant code from reaching production
- C Cheaper
- D Skip tests

Q242: Explanation

Correct Answer: B

Gates block risk:

- SAST, DAST, dependency scans
- Block on critical issues
- Automate policy

Critical Trap

Security gates block risk, not velocity.

Q243: Infrastructure as Code Risk

Question

What is the biggest risk in Infrastructure as Code?

- A Automation
- B Misconfiguration propagated at scale
- C Cheaper
- D Faster

Q243: Explanation

Correct Answer: B

Errors scale with IaC:

- Errors scale
- Secrets in code
- Review and scanning essential

Critical Trap

IaC errors replicate quickly; review and scan.

Q244: Secret Management

Question

Why should secrets be stored in a secrets manager?

- A Cheaper
- B Centralize protection, rotation, and access control of secrets
- C Slower
- D Easier to leak

Q244: Explanation

Correct Answer: B

Secrets managers centralize control:

- Central control
- Rotation
- Audit access

Critical Trap

Hardcoded secrets are a breach waiting to happen.

Q245: Serverless Security

Question

What is a key security consideration in serverless computing?

A. No security needed
B. Identity, permissions, and dependency risks in functions
C. Only backups
D. Only firewalls

Q245: Explanation

Correct Answer: B

Serverless still needs controls:

- Fine-grained IAM
- Dependency scanning
- Logging

Critical Trap

Serverless still requires IAM and dependency controls.

Q246: API Security

Question

Which is a top risk for APIs?

A. Marketing
B. Broken authentication and authorization
C. Cheaper
D. Backup cost

Q246: Explanation

Correct Answer: B

Auth flaws are top API risks:

- AuthN and AuthZ issues
- Rate limiting
- Input validation

Critical Trap

APIs are often attacked via auth flaws.

Q247: Mobile App Security

Question

Which is a key risk for mobile apps?

A. Marketing
B. Insecure storage of data on devices
C. Cheaper devices
D. Screen size

Q247: Explanation

Correct Answer: B

Local storage risks:

- Local storage risks
- Keychain or keystore use
- Encryption at rest

Critical Trap

Mobile devices are lost and stolen; protect local data.

Q248: Zero-Trust Microsegmentation

Question

What is microsegmentation?

- A Divide networks into very small, isolated zones
- B Backup strategy
- C Marketing term
- D Hiring practice

Q248: Explanation

Correct Answer: A

Microsegmentation isolates zones:

- Fine-grained segmentation
- Limits lateral movement
- Common in Zero Trust

Critical Trap

Microsegmentation reduces blast radius.

Q249: Post-Quantum Migration

Question

What is the recommended approach for post-quantum readiness?

A. Wait until quantum computers are practical

B. Inventory cryptography, plan migration, adopt hybrid approaches

C. Ignore

D. Replace all systems immediately

Q249: Explanation

Correct Answer: B

Plan post-quantum migration:

- Inventory current crypto
- Plan migration
- Hybrid schemes

Critical Trap

Quantum migration must be planned years in advance.

Q250: AI Data Poisoning

Question

What is data poisoning in AI systems?

A. Healthy training
B. Manipulating training data to corrupt model behavior
C. Faster training
D. Cheaper

Q250: Explanation

Correct Answer: B

Poisoned data corrupts models:

- Attacks training data
- Biases or corrupts outcomes
- Data validation matters

Critical Trap

Poisoned training data corrupts model outputs.

Q251: Non-Repudiation Principle

Question

Which control BEST supports non-repudiation?

A. Firewall
B. Digital signatures and immutable audit logs
C. Antivirus
D. Backups

Q251: Explanation

Correct Answer: B

Signatures and logs support non-repudiation:

- Signatures prove origin
- Immutable logs preserve evidence
- Both support non-repudiation

Critical Trap

Non-repudiation requires proof, not just policy.

Q252: Encryption Reversibility

Question

What distinguishes encryption from hashing?

- A Both are reversible
- B Encryption is reversible with a key; hashing is one-way
- C Both are one-way
- D Neither is reversible

Q252: Explanation

Correct Answer: B

Different purposes:

- Encryption protects confidentiality
- Hashing protects integrity
- Different purposes

Critical Trap

Encryption is reversible; hashing is not.

Q253: Certificate Expiry

Question

What happens when a certificate expires?

A. It is auto-renewed

B. It is no longer valid and trusting parties reject it

C. It is renewed by the browser

D. It stays valid

Q253: Explanation

Correct Answer: B

Expired certs are rejected:

- No longer trusted
- Causes outages
- Monitor expiry

Critical Trap

Expired certs break services.

Q254: Symmetric Key Distribution

Question

What is the MAIN challenge with symmetric encryption?

A. Slower speed

B. Secure key distribution between parties

C. Larger key sizes

D. Longer ciphertexts

Q254: Explanation

Correct Answer: B

Key distribution is the challenge:

- Shared key must be distributed
- Asymmetric helps establish
- Hybrid encryption is common

Critical Trap

Symmetric challenges are about key distribution, not speed.

Q255: Asymmetric Performance

Question

Why is asymmetric encryption rarely used for bulk data?

- A Not secure
- B Slower and computationally expensive
- C Keys are short
- D No integrity

Q255: Explanation

Correct Answer: B

Asymmetric is slow:

- Asymmetric is slow
- Used for key exchange or signatures
- Hybrid for bulk

Critical Trap

Asymmetric protects keys; symmetric protects bulk data.

Q256: Digital Certificate Chain

Question

What does certificate chaining provide?

A. Redundancy
B. Trust anchor linking leaf certs to a trusted root CA
C. Faster connections
D. Cheaper

Q256: Explanation

Correct Answer: B

Chain to trusted root:

- Chain to trusted root
- Enables validation
- Root of trust matters

Critical Trap

The trust chain ends at the root CA.

Q257: HSM Use Case

Question

Which is a typical use case for an HSM?

A. Marketing analytics

B. Root CA key protection and payment key management

C. Backup storage

D. Email filtering

Q257: Explanation

Correct Answer: B

HSMs protect high-value keys:

- High-value keys
- Regulated environments
- Physical tamper resistance

Critical Trap

HSMs protect high-value keys, not general storage.

Q258: Access Recertification Gap

Question

What is a common risk if access recertifications are skipped?

A. Nothing
B. Access creep and unauthorized access accumulating
C. Faster access
D. Fewer users

Q258: Explanation

Correct Answer: B

Access creep:

- Access accumulates
- Ex-employees retain access
- Privilege creep

Critical Trap

Skipping recertification enables access creep.

Q259: Behavior Analytics

Question

What is user and entity behavior analytics primarily used for?

A. Marketing

B. Detecting anomalous behavior that may indicate compromise

C. Backup storage

D. Encryption

Q259: Explanation

Correct Answer: B

UEBA detects anomalies:

- Baselines behavior
- Detects anomalies
- Complements SIEM

Critical Trap

UEBA detects anomalies, not signatures only.

Q260: Identity Provider Federation

Question

What is the primary benefit of identity federation?

A. Marketing

B. Users can access multiple systems with one trusted identity

C. Cheaper

D. Fewer controls

Q260: Explanation

Correct Answer: B

SSO across domains:

- Single identity
- Trust relationships
- SSO across domains

Critical Trap

Federation enables SSO but requires trust management.

Q261: Security Monitoring Maturity

Question

Which factor MOST improves security monitoring maturity?

A. More alerts
B. Tuned detection, playbooks, and skilled analysts
C. More tools
D. Larger budget

Q261: Explanation

Correct Answer: B

People, tuning, and playbooks:

- Tuning improves signal
- Playbooks speed response
- Skilled people matter

Critical Trap

Tools alone do not improve maturity.

Q262: Alert Fatigue Risk

Question

What is the MAIN risk of alert fatigue?

A. Fewer alerts
B. Critical alerts missed among noise
C. Lower cost
D. Higher uptime

Q262: Explanation

Correct Answer: B

Critical alerts missed:

- Analysts ignore alerts
- Detection misses real incidents
- Tune and prioritize

Critical Trap

Alert fatigue causes real incidents to slip.

Q263: Threat Hunting Benefit

Question

Which benefit does proactive threat hunting provide?

A. Cheaper licensing
B. Detection of threats that evade automated controls
C. Fewer analysts needed
D. Fewer logs

Q263: Explanation

Correct Answer: B

Hunting finds hidden threats:

- Finds hidden threats
- Human-led investigation
- Complements automation

Critical Trap

Hunting complements but does not replace automation.

Q264: Threat Intelligence Feeds

Question

How should threat intelligence feeds be used?

A. Blindly block all indicators

B. Contextualized use with validation for relevance

C. Ignore all feeds

D. Store for marketing

Q264: Explanation

Correct Answer: B

Use feeds with context:

- Not all feeds are accurate
- Context is required
- Blocking without context harms business

Critical Trap

Not every threat indicator applies to your environment.

Q265: IR Plan Testing

Question

Why should incident response plans be tested?

A. Compliance only

B. To verify roles, communications, and procedures work in practice

C. To slow downtime

D. To add cost

Q265: Explanation

Correct Answer: B

Testing reveals gaps:

- Tests reveal gaps
- Roles must be clear
- Communication tested

Critical Trap

Untested IR plans fail in real incidents.

Q266: Tabletop Value

Question

What is the main value of a tabletop IR exercise?

A. Cheaper

B. Tests decision-making, roles, and communication without production impact

C. Faster recovery

D. No risk

Q266: Explanation

Correct Answer: B

Tabletop tests decisions:

- Decision testing
- Role clarity
- Communication

Critical Trap

Tabletop validates decision-making, not technology only.

Q267: Incident Lessons

Question

Why should lessons be captured after incidents?

A. Blame

B. Improve processes, controls, and response capability

C. Close tickets faster

D. Marketing

Q267: Explanation

Correct Answer: B

Improve for the future:

- Continuous improvement
- Prevent recurrence
- Improve response

Critical Trap

Lessons without action are wasted learning.

Q268: Forensics Preservation

Question

Why is forensic preservation important during an incident?

A. Marketing

B. Supports investigation, legal action, and root cause analysis

C. Faster recovery

D. Cheaper

Q268: Explanation

Correct Answer: B

Preserve evidence:

- Preserve evidence
- Chain of custody
- Supports regulators and legal

Critical Trap

Poor preservation destroys evidence.

Q269: Vendor Breach Communication

Question

What should happen when a vendor notifies of a breach?

A. Ignore

B. Verify scope, assess impact, and coordinate response and notification

C. Blame the vendor

D. Wait for public disclosure

Q269: Explanation

Correct Answer: B

Assess and coordinate:

- Scope assessment
- Impact analysis
- Regulatory coordination

Critical Trap

Vendor breaches are your breaches to manage.

Q270: Patch Deployment Risk

Question

What is a key risk of rapid patch deployment without testing?

A. Cheaper
B. Patching can break production systems
C. Faster
D. Lower risk

Q270: Explanation

Correct Answer: B

Untested patches break production:

- Patches can cause regressions
- Staged rollout reduces risk
- Emergency bypass for zero-day threats

Critical Trap

Patching without testing trades one risk for another.

Q271: Secure Configuration Baseline

Question

What is a secure configuration baseline?

A. Vendor default

B. Documented secure settings derived from standards and validated

C. Marketing

D. Random settings

Q271: Explanation

Correct Answer: B

Baseline is documented secure state:

- Documented secure state
- Based on CIS, NIST, or vendor
- Drift detected against baseline

Critical Trap

Defaults are rarely secure.

Q272: Data Backup vs Archive

Question

What is the difference between backup and archive?

A. They are the same

B. Backup is for recovery; archive is for retention and reference

C. Archive is faster

D. Backup is cheaper

Q272: Explanation

Correct Answer: B

Backup vs archive:

- Backup for restore
- Archive for long-term retention
- Different retention policies

Critical Trap

Backup is not archive; archive is not backup.

Q273: Immutable Logs

Question

Why should logs be immutable?

A. Cheaper
B. Prevent tampering and preserve evidence
C. Faster search
D. Less storage

Q273: Explanation

Correct Answer: B

Immutable logs preserve evidence:

- Tamper-evident
- Supports forensics and audit
- Write-once storage

Critical Trap

Logs that can be modified cannot be trusted.

Q274: Encryption Key Custody

Question

What is the biggest risk of poor key custody?

- A Cheaper
- B Encryption becomes ineffective if keys are compromised
- C Slower
- D Smaller files

Q274: Explanation

Correct Answer: B

Compromised keys break encryption:

- Keys protect encryption
- Poor custody breaks security
- Key management critical

Critical Trap

Encryption without key custody is fake security.

Q275: Access Segregation Risk

Question

What risk does an effective segregation of duties prevent?

A. Slower work

B. Fraud and errors from concentrated control

C. Cheaper

D. Faster

Q275: Explanation

Correct Answer: B

SoD prevents concentrated control:

- Prevent concentration
- Reduce fraud
- Detect errors

Critical Trap

SoD prevents abuse of concentrated authority.

Q276: SIEM False Positives

Question

What is the best way to reduce SIEM false positives?

A. Disable all rules
B. Tune correlation rules with business context
C. Ignore all alerts
D. Reduce data

Q276: Explanation

Correct Answer: B

Tune rules:

- Tune rules
- Baseline behavior
- Add context

Critical Trap

Disabling rules removes visibility.

Q277: Access Token Risk

Question

What risk do stolen access tokens create?

- A Cheaper
- B Attackers can impersonate users without credentials
- C Slower
- D Smaller

Q277: Explanation

Correct Answer: B

Tokens act as credentials:

- Tokens act as credentials
- Short lifetime reduces damage
- Monitor and revoke

Critical Trap

Tokens must be protected like passwords.

Q278: Passwordless Authentication

Question

What is the main benefit of passwordless authentication?

A. Cheaper
B. Reduces phishing and credential compromise risk
C. Slower
D. Fewer users

Q278: Explanation

Correct Answer: B

Passwordless reduces phishing:

- No reusable password
- FIDO2 keys, biometrics
- Phishing resistant

Critical Trap

Passwordless reduces phishing, not all attacks.

Q279: Privacy by Design Trade-off

Question

What trade-off exists with privacy by design?

A. No trade-off

B. Some features may become harder to deliver due to minimized data collection

C. Higher quality

D. Faster

Q279: Explanation

Correct Answer: B

Limited data constrains features:

- Limited data constrains features
- Requires design work
- Long-term trust benefit

Critical Trap

Privacy by design trades convenience for trust.

Q280: Data Subject Access Request Timelines

Question

What is the typical GDPR time frame for responding to a data subject access request?

A. 24 hours

B. 30 days, extendable in some cases

C. 1 year

D. 5 years

Q280: Explanation

Correct Answer: B

One month response:

- One month
- Extendable for complexity
- Verify identity first

Critical Trap

GDPR DSAR response is one month, not one week.

Q281: Data Subject Rights Refusal

Question

When may an organization refuse a data subject request?

A. Never

B. Legal exemptions, third-party rights, or manifestly unfounded or excessive requests

C. Whenever convenient

D. Because it costs money

Q281: Explanation

Correct Answer: B

Legal justification required:

- Limited legal exemptions
- Document rationale
- Must explain refusal

Critical Trap

Refusals require legal justification.

Q282: HIPAA Breach Risk Assessment

Question

What must a HIPAA covered entity do after discovering a breach?

- A Ignore
- B Conduct a risk assessment to determine notification requirement
- C Notify all individuals
- D Publish a press release

Q282: Explanation

Correct Answer: B

Documented risk assessment:

- Risk assessment
- Notification requirements depend on results
- Presumption of breach unless low probability of compromise

Critical Trap

HIPAA requires a documented risk assessment.

Q283: CCPA Opt-Out

Question

What does CCPA require regarding opt-out of the sale of personal information?

A. Nothing
B. A clear "Do Not Sell My Personal Information" mechanism
C. Only verbal requests
D. Only via mail

Q283: Explanation

Correct Answer: B

CCPA requires opt-out mechanism:

- Opt-out right
- Clear mechanism
- Enforced

Critical Trap

CCPA requires opt-out mechanisms for sale.

Q284: Encryption Strength

Question

What determines the strength of encryption?

A. Amount of data
B. Algorithm and key length combined
C. Storage location
D. User count

Q284: Explanation

Correct Answer: B

Algorithm plus key length:

- Strong algorithm
- Sufficient key length
- Key management

Critical Trap

Encryption strength needs both algorithm and key length.

Q285: Digital Signature Verification

Question

How does a recipient verify a digital signature?

A. Using the sender's private key

B. Using the sender's public key

C. Using the recipient's private key

D. Using the recipient's public key

Q285: Explanation

Correct Answer: B

Verify with sender public key:

- Sender signs with private key
- Recipient verifies with public key
- Ensures authenticity

Critical Trap

Verify signatures with the sender's public key.

Q286: Security Awareness for Executives

Question

Why do executives need specialized security awareness?

A. They don't need training

B. They are prime targets for spear phishing and social engineering

C. They already know everything

D. It is optional

Q286: Explanation

Correct Answer: B

Executives are top targets:

- High-value targets
- Specialized risks
- Frequent attacks

Critical Trap

Executives are top phishing targets.

Q287: Whaling Attack

Question

What is a whaling attack?

- A Attack on whales
- B Targeted phishing on senior executives
- C Attack on routers
- D Network attack

Q287: Explanation

Correct Answer: B

Whaling targets executives:

- High-value target
- Spear phishing variant
- Executive protection matters

Critical Trap

Whaling = executives targeted by phishing.

Q288: Tabletop for Board

Question

Why would a board participate in a cyber tabletop exercise?

A. Entertainment

B. Test crisis decision-making and board oversight during a major incident

C. Compliance only

D. Marketing

Q288: Explanation

Correct Answer: B

Board tests crisis oversight:

- Governance during crisis
- Decision rights
- Board roles

Critical Trap

Boards need to practice oversight under stress.

Q289: Risk of Unpatched Middleware

Question

Why is unpatched middleware particularly dangerous?

- A Marketing
- B Middleware sits between applications and databases and can expose high-value systems
- C Cheaper
- D Faster

Q289: Explanation

Correct Answer: B

Middleware has amplified impact:

- High-value position
- Broad impact
- Critical patch priority

Critical Trap

Middleware vulnerabilities have amplified impact.

Q290: API Key Storage Risk

Question

What is the main risk of API keys hardcoded in code?

A. Cheaper

B. Leakage through code repositories or logs

C. Faster

D. Lower risk

Q290: Explanation

Correct Answer: B

Code leaks secrets:

- Code is copied
- Repos leak
- Use secret managers

Critical Trap

Hardcoded secrets are exposed to anyone with code access.

Q291: Continuous Compliance

Question

What is continuous compliance in cloud environments?

A. Annual audits

B. Continuous automated monitoring against compliance rules

C. Quarterly reviews

D. Never

Q291: Explanation

Correct Answer: B

Continuous checks:

- Automated checks
- Real-time detection
- Remediation

Critical Trap

Continuous compliance detects drift continuously.

Q292: CAIQ vs SOC 2

Question

What is the difference between CAIQ and SOC 2?

A. They are the same

B. CAIQ is a self-assessment questionnaire; SOC 2 is independent audit

C. CAIQ is an audit

D. SOC 2 is a questionnaire

Q292: Explanation

Correct Answer: B

Self-report vs audit:

- CAIQ is self-report
- SOC 2 is audited
- Different assurance levels

Critical Trap

CAIQ is self-assessment; SOC 2 is independent.

Q293: SaaS Misconfiguration

Question

What is the most common cause of SaaS data exposure?

- A Vendor vulnerability
- B Customer misconfiguration of permissions or sharing
- C Cheaper
- D Storage limits

Q293: Explanation

Correct Answer: B

Customer misconfigurations:

- Permissions
- Public sharing
- Shared responsibility

Critical Trap

Most SaaS breaches are customer misconfigurations.

Q294: Identity in Cloud

Question

What is the most critical control for cloud security?

A. Firewalls
B. Strong identity and access management
C. Antivirus
D. Backups

Q294: Explanation

Correct Answer: B

Cloud security starts with IAM:

- IAM is fundamental
- Least privilege
- MFA

Critical Trap

Cloud security starts with IAM.

Q295: Cloud Encryption

Question

What is the main challenge with cloud encryption?

A. Slower
B. Key management and provider access
C. Cheaper
D. Less storage

Q295: Explanation

Correct Answer: B

Key custody matters:

- Key custody
- Provider access
- BYOK and HYOK options

Critical Trap

Cloud encryption depends on key control.

Q296: Data Loss in Cloud

Question

What causes data loss in cloud environments?

A. Provider failures only

B. Misconfiguration, deletion by attacker, insufficient backups

C. Cheaper storage

D. Faster networks

Q296: Explanation

Correct Answer: B

Often customer-caused:

- Misconfigurations
- Accidental deletion
- Backups matter

Critical Trap

Cloud data loss is often customer-caused.

Q297: Security Metrics

Question

Which security metric is most valuable to executives?

A. Number of CVEs fixed
B. Trend in risk exposure against appetite and business impact
C. Firewall rule count
D. Number of employees

Q297: Explanation

Correct Answer: B

Business context matters:

- Business impact matters
- Appetite alignment
- Trends show direction

Critical Trap

Executives need business context, not raw counts.

Q298: Risk Acceptance in Security

Question

Who should accept residual security risk?

A. The security team
B. The business owner, informed by security
C. The vendor
D. The auditor

Q298: Explanation

Correct Answer: B

Business owns risk:

- Business owns risk
- Security advises
- Documented acceptance

Critical Trap

Security advises; business owners accept risk.

Q299: Security Program Maturity

Question

What BEST indicates high security program maturity?

A. More tools

B. Risk-based decisions, metrics, and continuous improvement

C. Larger budgets

D. Fewer incidents

Q299: Explanation

Correct Answer: B

Maturity is outcomes:

- Risk-based
- Measured
- Improving

Critical Trap

Maturity is about outcomes and improvement, not tools.

Q300: Ultimate Security Truth

Question

What is the ultimate truth about security?

A. Security can be perfect

B. Security can never be perfect; it is continuous risk management

C. Security is a one-time project

D. Security is a purchase

Q300: Explanation

Correct Answer: B

Security is continuous:

- No perfect security
- Continuous risk management
- Balance risk and cost

Critical Trap

Security is continuous, not a one-time achievement.

Exam Mindset Summary

Remember

- **CIA triad:** Confidentiality, Integrity, Availability
- **Signatures** provide integrity, authenticity, non-repudiation
- **Encryption is reversible; hashing is one-way**
- **Privacy** is about rights; **security** is about protection
- **Zero Trust:** verify every access
- **DLP, PAM, SIEM, WAF, HSM, KMS:** know what each does
- **Cloud:** shared responsibility; data location matters
- **Maturity:** continuous improvement and metrics
- **Security is continuous risk management**

Thank You

Good Luck on Your CRISC Exam!